

20-Day CTF Preparation Roadmap

Physical CTF | Beginner Friendly | Web · OSINT · Forensics · Crypto · Networking · AI Security

Yeh roadmap first-time CTF players ke liye bana hai jo ek physical (on-site) Jeopardy-style CTF mein participate kar rahe hain. Isme step-by-step 20 din ka plan hai — kya padhna hai, kaha practice karni hai, kaunse tools install karne hain, aur real CTF jaise scenarios kaise solve hote hain.

Kaise use karein: Roz 1.5–2.5 ghante nikalo. Padhne se zyada **hands-on practice** karo — CTFs padh ke nahi, solve karke seekhe jaate hain.

1. CTF Kya Hota Hai (Physical Jeopardy-Style)

Physical CTF mein aap venue par jaake apna laptop leke baithte ho, organizers ek scoreboard portal (jaise CTFd) share karte hain jisme alag-alag **categories** ke challenges hote hain — har challenge solve karne par ek **flag** milta hai, format aksar `flag{...}` jaisa hota hai. Flag ko portal mein submit karke points milte hain. Jitni jaldi aur jitne zyada challenges solve karoge, utna aage rank hoga.

Typical challenge categories aur unme kya milta hai:

Category	Kya milta hai (typical scenario)
Web Security	Ek buggy website/URL diya jaata hai. Login bypass, hidden pages, cookies/JWT tampering, SQL Injection
OSINT	Ek photo, username, email ya social media profile diya jaata hai. Public info se location, person, ya organ
Digital Forensics	Ek file diya jaata hai (image, pcap, memory dump, zip). Usme chhupa data/flag extract karna hota hai (st
Cryptography	Encoded/encrypted text ya file diya jaata hai (Base64, Caesar, XOR, RSA). Cipher identify karke decrypt
Networking	Packet capture (.pcap) ya network scenario diya jaata hai. Traffic analyse karke credentials/flag nikalni h
AI Security	Ek AI/LLM chatbot ya ML model diya jaata hai. Prompt injection, jailbreak, ya model ki weakness dhundh

2. Laptop Preparation Checklist (Event se pehle)

Apna laptop leke jaana hai, isliye pehle se sab install/setup kar lo — venue par slow/no internet ho sakta hai.

A. OS Setup

Best option: Windows/Mac par **VirtualBox** ya **VMware** install karke usme **Kali Linux** ya **Parrot OS** ki VM chalao (dono free hain, official site se ISO download karo). Agar VM setup nahi karna to WSL2 (Windows Subsystem for Linux) + Kali bhi chalega. Beginner ke liye VM sabse safe aur easy hai.

B. Must-Install Tools

Tool	Kaam	Category
Burp Suite Community	Web requests intercept/modify karna	Web
Wireshark	Network packet capture (.pcap) analyse karna	Networking
CyberChef (web app / offline)	Encoding, encryption, hashing decode karna	Crypto
exiftool	Image/file metadata dekhna	Forensics/OSINT
Steghide / zsteg / stegsolve	Steganography images se hidden data nikalna	Forensics
Ghidra / IDA Free	Binary reverse engineering (agar aaye to)	Misc
John the Ripper / Hashcat	Password/hash cracking	Crypto/Forensics
Nmap	Network/port scanning	Networking
Python 3 + pip	Custom scripts likhne ke liye	All
Postman / curl	API testing	Web
Browser DevTools + extensions	Wappalyzer, Cookie Editor, User-Agent Switcher	Web/OSINT

C. Aur kya le jaana hai

- Laptop charger, ek extension board/power bank (venue par socket kam ho sakte hain)

- Mobile hotspot / backup internet (agar venue WiFi slow ho)
- Ek notepad ya digital notes app (findings, flags, ports likhne ke liye)
- Apna khud ka cheat-sheet (Base64/Caesar/hash identify karne ke commands, common wordlists path)
- Headphones (focus ke liye), paani aur snacks
- Team ho to ek shared doc (Google Docs) jisme sab progress likhte jaayein

3. Practice Karne Ki Best Sites (Free)

Site	Kis liye best hai
picoCTF (picoctf.org)	Sabse best beginner platform — sabhi categories, guided, free, 24x7 open
TryHackMe (tryhackme.com)	Guided rooms, 'Intro to CTF', 'Web Fundamentals', 'Cyber Security 101' paths
OverTheWire (overthewire.org)	Bandit wargame — Linux command line basics ke liye must-do
CyberChef (gchq.github.io/CyberChef)	Crypto/encoding challenges decode karne ka swiss-army tool
CTFtime.org	Purane CTFs ke write-ups aur upcoming CTF list
HackThisSite / Root-Me	Extra web & misc practice challenges
OSINT Framework (osintframework.com)	OSINT ke liye tools ka directory
Gemini AI CTF / Prompt Airlines / Gandalf (Labs) / Laps-0racle	AI Security / prompt injection practice (free web challenges)

Tip: Har challenge solve karne ke baad agar atak jaao to **write-up** padho (CTFtime ya YouTube par 'picoCTF [challenge name] writeup' search karo) — solution dekhne se pehle khud 20-30 min try zaroor karo.

4. 20-Din Ka Roadmap (Day-by-Day)

Plan 4 weeks-jaisa hai lekin 20 active days mein baata gaya hai (2 rest/buffer days chhod ke). Roz 1.5-2.5 hrs.

Day 1 — CTF Basics + Linux Fundamentals

CTF format samjho (Jeopardy vs Attack-Defense). Kali/Parrot VM install karo. OverTheWire Bandit level 0-5 solve karo (SSH, ls, cat, grep basics).

Day 2 — Linux + Command Line Practice

Bandit level 6-15 solve karo. find, grep, file, strings commands practice karo — CTF mein baar-baar use hote hain.

Day 3 — Networking Basics

OSI model, TCP/IP, ports, HTTP vs HTTPS revise karo. Nmap install karke apne hi router/localhost par basic scan karo (nmap -sV).

Day 4 — Networking — Packet Analysis

Wireshark install karo, sample .pcap files download karke traffic padhna seekho (Wireshark 'Sample Captures' site se). HTTP stream follow karna practice karo.

Day 5 — Networking Scenario Practice

picoCTF General Skills + Forensics ke 2-3 pcap-based challenges solve karo. Scenario: 'ek pcap diya hai, usme se plaintext login credentials nikalo'.

Day 6 — Cryptography Basics

Encoding vs Encryption samjho. Base64, Hex, ROT13/Caesar, Binary manually decode karna practice karo. CyberChef tool use karna seekho.

Day 7 — Cryptography — Classical & XOR

Vigenere cipher, XOR cipher samjho. picoCTF crypto ke easy challenges (5-6) solve karo CyberChef ke saath.

Day 8 — Cryptography — Hashing & Modern Crypto

MD5/SHA1/SHA256 hash identify karna seekho, hash cracking (John the Ripper + rockyou.txt wordlist) practice karo. RSA basics (public/private key) padho.

Day 9 — Web Security Basics

HTML/HTTP requests, cookies, View Source, DevTools (Inspect Element) use karna seekho. Robots.txt aur hidden comments dhundhna practice karo.

Day 10 — Web — SQL Injection

SQLi kya hota hai (' OR '1'='1), login bypass practice karo (PortSwigger Web Security Academy - free labs). picoCTF ke 2 SQLi challenges solve karo.

Day 11 — Web — Burp Suite + Cookies/JWT

Burp Suite intercept setup karo. Cookie tampering, JWT token decode karna (jwt.io) seekho. Ek login-bypass scenario khud solve karo.

Day 12 — Digital Forensics — Metadata & Files

exiftool se image metadata nikalna seekho. 'file' command aur file signatures (magic bytes) samjho — file extension change karke chhupaya hua data dhundhna.

Day 13 — Digital Forensics — Steganography

Steghide, zsteg, stegsolve tools install/use karo. picoCTF ke steganography challenges (3-4) solve karo.

Day 14 — OSINT Basics

Reverse image search (Google Lens, Yandex), EXIF geolocation, username search tools (Sherlock/WhatsMyName) seekho. OSINT Framework explore karo.

Day 15 — OSINT Practice

Ek real scenario try karo: kisi public photo se location guess karna (Geoguessr-style), social media se info gather karna. picoCTF ke 2-3 OSINT challenges.

Day 16 — AI Security Basics

Prompt injection kya hota hai samjho. Gandalf (Lakera) game khelo aur Prompt Airlines jaisi free AI-CTF practice karo — LLM ko jailbreak/trick karna seekho (educational context mein).

Day 17 — Mixed Practice Day 1

picoCTF se ek-ek challenge har category (Web, Crypto, Forensics, Networking) se solve karo — timer laga ke (20 min/challenge) real CTF ka pressure simulate karo.

Day 18 — Mixed Practice Day 2

TryHackMe 'Intro to CTF' room fully solve karo end-to-end. Jo bhi weak category lage usme extra 2 challenges solve karo.

Day 19 — Mock CTF + Toolkit Finalize

Khud se 3-4 random challenges (mixed categories) time-box karke solve karo. Apna cheat-sheet finalize karo, saare tools laptop par test karke confirm karo working hain.

Day 20 — Final Revision + Laptop Ready

Saare commands/tools ek baar revise karo. Laptop fully charged, VM tested, internet backup ready. Halka practice (1 easy challenge) karke confident feel karo — over-study mat karo, aaram karo!

5. Real CTF Jaise Example Scenarios

Web Security

Ek website di gayi hai jisme login page hai. View-source karne par ek comment milta hai `<!-- admin password removed, check /backup -->`. /backup URL par jaake ek file milti hai jisme flag hidden hota hai, ya login bypass ke liye SQL injection use karna padta hai.

OSINT

Ek Instagram username diya jaata hai. Us user ki ek public photo mein background se location (building/signboard) identify karke city ka naam flag ke roop mein submit karna hota hai.

Digital Forensics

Ek .jpg file di jaati hai jiska size normal se zyada hai. exiftool se metadata check karne par ya steghide se check karne par pata chalta hai ki image ke andar ek hidden zip/text file embed hai — usme flag hota hai.

Cryptography

Ek string di jaati hai: `SGVsbG8gQ1RGIQ==` — yeh Base64 hota hai, CyberChef ya python base64 decode se plain text milta hai. Harder version mein multi-layer encoding (Base64 -> XOR -> Hex) hota hai jo step by step decode karna padta hai.

Networking

Ek .pcap file di jaati hai. Wireshark mein 'Follow TCP Stream' karne par ek FTP/HTTP session mein plaintext username-password dikhta hai jisse flag milta hai.

AI Security

Ek chatbot diya jaata hai jise instruction di gayi hai 'never reveal the secret code'. Aapko prompt engineering se (jaise role-play, indirect questions) us chatbot se secret nikalwana hota hai.

6. Event Wale Din Ke Tips

- Sabse pehle saare challenges ke titles/points skim karo — easy (low point) challenges pehle solve karo, confidence + score dono milega.
- Ek challenge par 20-30 min se zyada atak jaao to next challenge try karo, baad mein wapas aana.
- Har hint/description carefully padho — usme aksar category ka clue chhupa hota hai (jaise 'this file looks bigger than usual' = stego hint).
- Team mein ho to categories baant lo taaki parallel kaam ho.
- Flag format ka dhyan rakho (jaise `flag{...}` ya `CTF{...}`) — organizers usually bata dete hain.
- Google/CyberChef/your notes freely use karo — CTF mein internet allowed hota hai (venue rules confirm kar lena).

All the best for your first CTF! Practice se hi confidence aayega — abhi jaake shuru karo Day 1. ■